

Security Auditing & Digital Forensics

Comprehensive Exam Worksheet — Practice Questions

Master in Informatics Security (MSI) / Engineering (MEI) — University of Coimbra

Built from the 2025/2026 course material (lessons T1–T10)

How to use this worksheet. The questions imitate the style of the real exam: short, applied, concept-driven statements (*open book*, ≈ 1.5 points each). Each section opens with a brief **Context** box that frames the topic — it does *not* contain the answers. Try to answer from memory first, then check yourself against the full **Answer Key** at the end of this document.

★ = question **adapted from a previous official exam** (2022), re-mapped to the current syllabus (e.g. old ISO 27001:2013 numbering updated to the 2022 control set).

Contents

1	The Need for ISS Compliance (Assessments, Audits, Governance)	1
2	Defining & Planning an IT Security Audit (Domains & Controls)	2
3	The ISO/IEC 27000 Family & the ISMS	2
4	ISO 27002 Controls & Information-Security Risk	3
5	Other ISO Standards, Implementation & Certification	3
6	NIST Cybersecurity Framework (CSF) 2.0	4
7	NIS2 Directive & GDPR	5
8	DORA, the EU Cybersecurity Act & SOC 2	5
9	Introduction to Digital Forensics & Forensic Readiness	6
10	Endpoint Forensics — Memory & Volatility	7
11	Scaling the Investigation — Enterprise Forensics by Design	8
12	Synthesis & Cross-Cutting Scenarios	9

1. The Need for ISS Compliance (Assessments, Audits, Governance)

Context — Lesson T1

Information Systems Security (ISS) compliance is the activity of conforming to internal policies and external regulations. The course distinguishes **assessment** (an internal, improvement-oriented health-check, non-attributive) from **audit** (an independent, pass/fail evaluation with consequences). Both sit inside a **risk-based** cycle (categorize → select controls → implement → assess → authorize → monitor) and inside the triangle of **Risk Management / Compliance / Governance**.

- Q1. Define “IT security assessment” and “IT security audit” and state **two** concrete differences between them in terms of attribution of blame and consequences.
- Q2. List the six steps of the risk-based approach to information security management, in order.
- Q3. Explain the relationship between Risk Management, Compliance and Governance: how does compliance support risk management, and what does governance add?
- Q4. An auditor is asked to evaluate a system that the same auditor designed last year. Explain why this is a problem and which audit principle it violates.
- Q5. Name the five types of audit covered (financial, compliance, operational, investigative, IT) and give a one-line scope for each.
- Q6. A manager limits the audit to two weeks and withholds records of past incidents. Classify these actions and describe their negative impact on the audit.
- Q7. Describe **four** organizational barriers that typically make IT compliance fail, and propose a mitigation for each.
- Q8. Distinguish a *policy*, a *standard* and a *guideline*, and order them from most to least binding.

2. Defining & Planning an IT Security Audit (Domains & Controls)

Context — Lesson T2

Planning an audit means fixing **scope** (what + time period), **goals**, **objectives** and **frequency**, then collecting documentation and interviewing people across the **seven domains of a typical IT infrastructure** (User, Workstation, LAN, LAN-to-WAN, WAN, Remote Access, System/Application). Key cross-cutting controls include **configuration** and **change management**, **threat/vulnerability analysis**, and **privacy management**.

- Q1. ★ Consider the supplier-relationship control area of ISO 27001 (2022 controls **A.5.19–A.5.22**, “Information security in supplier relationships”). Give an example of a concrete control that contributes to this objective and justify how it reduces risk.
- Q2. ★ Describe the **four** security controls you consider most important for the **System/Application Domain** of an IT infrastructure, and justify your choice.
- Q3. Name the seven domains of a typical IT infrastructure and, for the **LAN-to-WAN Domain**, list the typical equipment and the main security concern.

- Q4.** Differentiate **configuration management** from **change management**, and list the five steps of the change-control process.
- Q5.** For a firewall, list **five** items that must appear in its configuration documentation.
- Q6.** During threat analysis an auditor must classify threat sources. Give one example each of an *adversarial*, *accidental*, *structural* and *environmental* threat.
- Q7.** When pairing a threat with a vulnerability, the level of risk depends on three factors. State them, and explain the three trade-offs (cost, operational impact, feasibility) used to decide whether a control is worth deploying.
- Q8.** List four kinds of documentation an auditor should request before fieldwork, and explain why knowing the organization's existing policy *framework* matters to the audit.
- Q9.** Give two reasons why testing and monitoring are described as the “most beneficial” elements of an IT security program.

3. The ISO/IEC 27000 Family & the ISMS

Context — Lesson T3

The ISO/IEC 27000 series is a family of standards for managing information-security risk. **ISO 27001** is the only *certifiable* standard; it defines an **ISMS** (Information Security Management System) built on the **Plan–Do–Check–Act** cycle and aimed at protecting the **CIA triad** (confidentiality, integrity, availability). Supporting members: 27002 (controls guidance), 27003 (ISMS implementation), 27005 (risk), 27007 (auditing), 27017/27018 (cloud/PII), 27701 (privacy), 27035 (incidents).

- Q1.** State which ISO 27000 standard is the only one an organization can be **certified** against, and explain what that certification actually attests.
- Q2.** Explain the difference in purpose between ISO 27001 and ISO 27002 using one short “Annex A vs. implementation guidance” example.
- Q3.** Define an ISMS and name the four categories of controls it organizes (organizational, people, physical, technological).
- Q4.** The ISMS is based on the PDCA cycle. Briefly describe what happens in each of the four phases for information security.
- Q5.** Leadership and commitment is listed as a core ISMS component. Explain why, without top-management buy-in, an ISMS implementation typically fails.
- Q6.** Match each standard to its domain: 27005, 27017, 27018, 27035, 27701.
- Q7.** Give two business benefits and two consequences of *not* adopting ISO 27000, citing the kind of incident the standard is meant to prevent.

4. ISO 27002 Controls & Information-Security Risk

Context — Lesson T4

The 2022 revision of ISO 27002 consolidated the old 14 control categories into **4 themes** — Organizational (A.5), People (A.6), Physical (A.7), Technological (A.8) — and added 5 **attributes** to tag controls (Preventive, Detective, Corrective, plus Governance/Assurance views). Controls are chosen via a **risk assessment** and recorded in the **Statement of Applicability (SoA)**. Risk treatment offers four options: **Avoid, Transfer, Mitigate, Accept**.

- Q1.** Name the four control themes of ISO 27002:2022 and give two example controls from each.
- Q2.** Classify the following as Preventive, Detective or Corrective: (a) MFA, (b) SIEM log monitoring, (c) restoring from backup after ransomware, (d) firewall rules.
- Q3.** Define the **Statement of Applicability** and explain how a risk assessment feeds into selecting controls from ISO 27002.
- Q4.** For each of the four risk-treatment options (avoid, transfer, mitigate, accept) give a concrete example. For one of them, explain when it is the *rational* choice.
- Q5.** Explain “risk appetite” and how it is used during **risk evaluation** to decide which risks need treatment.
- Q6.** A control reduces likelihood but costs more than the expected loss it prevents. Using the cost/operational-impact/feasibility trade-offs, argue what the organization should do.
- Q7.** Map the control families A.5.7 (Threat Intelligence), A.8.16 (Monitoring), A.8.17 (Clock synchronization) to a forensic-readiness benefit you studied later in the course.

5. Other ISO Standards, Implementation & Certification

Context — Lesson T5

Beyond the core, the family specializes: **27017** (cloud security & the shared-responsibility matrix across IaaS/PaaS/SaaS), **27018** (PII in the cloud), **27019** (energy/OT & SCADA), **27701** (PIMS for GDPR), **27035** (incident management). Certification follows a roadmap (scope → risk assessment → controls → policies → internal audit → certification), with a **Stage 1** (documentation) and **Stage 2** (on-site) external audit; the certificate is valid 3 years with annual surveillance audits.

- Q1.** In a **SaaS** model, who controls the application, platform, virtual infrastructure and physical infrastructure? Contrast this with **IaaS** and explain the “shared-responsibility” idea behind ISO 27017.
- Q2.** State the purpose of ISO 27018 and give two privacy principles it enforces for PII in the cloud (e.g. user-consent management, right to erasure).
- Q3.** Why does the energy sector get its own standard (ISO 27019)? Name one OT/ICS-specific threat it addresses.
- Q4.** Describe the two stages of an external certification audit and what the auditor verifies in each.

- Q5.** Distinguish a **first-party (internal)** audit from a **third-party certification** audit, and state who performs each.
- Q6.** List the four phases of incident management under ISO 27035-2.
- Q7.** A healthcare provider failed its ISO 27001 implementation. Give three likely failure points (from the case study) and the lesson learned from each.
- Q8.** After certification, what must an organization do to keep its certificate valid over the three-year cycle?

6. NIST Cybersecurity Framework (CSF) 2.0

Context — Lesson T6

The NIST CSF is a **voluntary**, risk-based framework. Version **2.0 (2024)** expanded the Core from 5 to **6 functions** by adding **Govern: Govern, Identify, Protect, Detect, Respond, Recover**. It also has **Implementation Tiers** (1 Partial → 4 Adaptive) describing maturity, and **Profiles** (Current vs. Target + action plan) for tailoring. It maps cleanly to ISO 27001, NIST 800-53, CIS Controls and Zero Trust.

- Q1.** Name the six functions of CSF 2.0 in order and state, in one line each, what each function is responsible for.
- Q2.** Which function is **new** in CSF 2.0 and why was it added? What does it embed into the organization?
- Q3.** Explain the difference between an **Implementation Tier** and a **Profile**. Name the four tiers.
- Q4.** An organization wants to adopt CSF. Describe how it would use a Current Profile, a Target Profile and a gap analysis to build an action plan.
- Q5.** Match these metrics to a CSF function: MTTD, MTTR, Patch-management time, Phishing click-rate.
- Q6.** CSF is voluntary — give two reasons organizations still adopt it (e.g. due-diligence, regulatory references).
- Q7.** For each emerging threat — AI-based attacks, cloud misconfiguration, ransomware double extortion, supply-chain attacks — name the CSF function you would strengthen.

7. NIS2 Directive & GDPR

Context — Lesson T7 (part 1)

NIS2 is an EU directive raising cyber-resilience: it widens sector coverage, splits entities into **Essential** vs. **Important**, mandates supply-chain security and MFA, makes management **personally liable**, and sets strict incident reporting (**24h** early warning, **72h** full report, 1-month final). **GDPR** protects personal data: it has **extraterritorial** scope, six **legal bases** for processing, core **principles**, eight **data-subject rights**, a **72h** breach notification, and a **two-tier** fine structure.

- Q1. ★** Describe the main role of **ENISA** (the EU Agency for Cybersecurity) and the EU-level **CSIRT cooperation** it supports, as established by EU Regulation 2019/881 (the Cybersecurity Act).
- Q2.** Give the NIS2 incident-reporting timeline (early warning / full report / final assessment) and state who the report goes to.
- Q3.** Distinguish **Essential Entities** from **Important Entities** under NIS2, including the size threshold and the difference in supervision.
- Q4.** NIS2 makes executives “personally liable.” Explain what obligations this places on senior management and what penalties non-compliance can bring (cite the fine ceiling).
- Q5.** List the six GDPR legal bases for processing. For an e-commerce shipping address and for a fraud-detection log, state which basis you would rely on.
- Q6.** State the GDPR breach-notification rule (Article 33) and the one condition under which notifying affected individuals (Article 34) is *not* required.
- Q7.** A non-EU company with no EU office tracks EU users with advertising cookies. Explain why GDPR still applies (territorial scope, Art. 3(2)).
- Q8.** Define the roles of **data controller**, **data processor** and **DPO**.
- Q9.** GDPR has a two-tier fine structure. State the two ceilings (percentage of turnover and euro amount) and give one example of a violation in each tier.
- Q10.** Name four GDPR data-subject rights and, for “right to be forgotten,” give a situation where it can be lawfully refused.

8. DORA, the EU Cybersecurity Act & SOC 2

Context — Lesson T7 (part 2)

DORA (Digital Operational Resilience Act) targets the EU **financial** sector and its ICT third parties: ICT risk management (Identify→Assess→Mitigate →Monitor), incident reporting, and — importantly for forensics — Article 13’s requirement to consider the “quality and speed of forensic analysis.” The **EU Cybersecurity Act** gives ENISA a permanent mandate and creates EU-wide **certification schemes** with three assurance levels (Basic/Substantial/High). **SOC 2** (AICPA) assures a service organization’s controls against five Trust Services Criteria; **Type II** tests *operating effectiveness over a period*.

- Q1.** Which sector does DORA target, and which non-financial organizations does it still capture? List the four steps of its ICT risk-management cycle.
- Q2.** Explain how DORA Article 13 links *forensic readiness* to compliance for financial entities (think “speed of analysis”).
- Q3.** State the three assurance levels of the EU Cybersecurity Act certification schemes and explain the benefit of “mutual recognition” across member states.
- Q4.** Differentiate **SOC 2 Type I** from **Type II** (point-in-time design vs. operating effectiveness over 3–12 months).
- Q5.** Name the five Trust Services Criteria of SOC 2 and state which one is mandatory in every report.

- Q6.** List the four control-testing methods auditors use in a SOC 2 engagement (inquiry, inspection, observation, re-performance) and give an example of each.
- Q7.** DORA, NIS2 and GDPR overlap. Give one benefit and one challenge of treating them with a single integrated compliance approach.

9. Introduction to Digital Forensics & Forensic Readiness

Context — Lesson T8

Forensics shifts the lens from the **auditor** (verifies controls *exist*) to the **investigator** (re-constructs what *happened*). It rests on legal pillars: **Locard's exchange principle** ("every contact leaves a trace"), **chain of custody**, **hashing** for integrity, **write-blockers**, the **order of volatility** (RFC 3227), and **bit-stream imaging**. **Forensic readiness** = maximizing usable evidence while minimizing investigation cost, built on five pillars (time sync, advanced logging, legal mandate, triage tools, trained first responders) and tied to NIS2/DORA "due care."

- Q1.** ★ Describe two example situations that illustrate the importance of a **Code of Ethics / deontology** in an IT security auditing or forensic process.
- Q2.** Contrast the *auditor's* perspective with the *investigator's* perspective on the same compromised server.
- Q3.** State Locard's exchange principle and give two examples of digital "traces" a Windows machine leaves (e.g. LNK files, registry/USB logs).
- Q4.** List the order of volatility (RFC 3227) from most to least volatile, and explain why an incident-response plan that "reboots the server first" destroys evidence.
- Q5.** Explain why and how forensic integrity is verified with hashing. Why is **dual hashing** (e.g. MD5 + SHA-256) sometimes used?
- Q6.** Define a hardware **write-blocker** and explain what unwanted writes a Windows workstation would make if you simply plugged in a suspect drive.
- Q7.** Contrast **live** vs. **dead** acquisition. Give one scenario where live acquisition is the *only* option (hint: full-disk encryption).
- Q8.** Distinguish a **logical copy** from a **physical bit-stream image** and state two artifact types only the bit-stream captures.
- Q9.** File signatures (magic bytes): give the header bytes for an executable, a PDF and a JPEG, and explain why an investigator trusts the header over the file extension.
- Q10.** Name the five pillars of forensic readiness. For **time synchronization**, explain why sub-second accuracy can decide whether evidence is admissible in court.
- Q11.** Under NIS2, why can a company that "cannot prove how a breach happened" be deemed *negligent*? Connect this to mandatory 24/72-hour reporting.
- Q12.** Explain the tension between the IR goal (business continuity) and the forensic goal (preservation), and describe the "forensic-aware IR" compromise (snapshots over wipes).

10. Endpoint Forensics — Memory & Volatility 3

Context — Lesson T9

Modern (“fileless”) malware often lives only in **RAM**, so memory forensics is essential. Memory is acquired in software (Magnet RAM Capture, LiME, AVML) or hardware/DMA (PCILeech, MemProcFS) — noting the speed order **DMA** < **Network** < **Software** and artifacts like `hiberfil.sys`, `pagefile.sys`, crash dumps. **Volatility 3** rewrote the engine in Python 3, replacing fragile *profiles* with on-the-fly *symbols* (ISF/PDB) and “Automagic” OS detection. Plugins follow `[OS].[plugin]` syntax (`windows.pslist`, `windows.malfind`, ...).

- Q1.** Why does static (disk-only) analysis miss “fileless” threats? Name three things that exist *only* in RAM.
- Q2.** Distinguish the four memory artifact types: physical RAM dump, `hiberfil.sys`, `pagefile.sys`, and crash dump (`.dmp`).
- Q3.** Explain the key architectural change from Volatility 2 to Volatility 3 (*profiles* → *symbols*) and what “Automagic” automates.
- Q4.** Order these acquisition methods by speed (DMA, network, software) and give one advantage and one limitation of hardware/DMA capture (e.g. IOMMU/VT-d).
- Q5.** Distinguish the plugins `windows.pslist`, `windows.pstree` and `windows.psscan`; which one finds a hidden/terminated process and why?
- Q6.** You suspect C2 traffic. Which Volatility plugin lists active sockets, and what pattern (ports/IPs) would raise suspicion?
- Q7.** Explain what `windows.malfind` flags as code injection (RWX memory, unbacked pages, “MZ” headers) and why an “MZ” string in `explorer.exe`’s heap is suspicious.
- Q8.** Which plugin enumerates Run-key autostart entries from the registry hive in memory, and why is that a persistence indicator?
- Q9.** After identifying a malicious PID, which plugins dump its cached files/memory for reverse engineering, and where would you analyze the output?
- Q10.** Explain what MemProcFS does differently from classic Volatility and one benefit of “memory-as-a-drive.”
- Q11.** Give the immediate post-acquisition integrity step and why recording the BIOS-vs-real time offset matters.

11. Scaling the Investigation — Enterprise Forensics by Design

Context — Lesson T10

At enterprise scale (1000+ endpoints, hybrid cloud, encryption everywhere) the “image-everything” model breaks. The answer is **remote triage**: collect the *golden artifacts* fast. **KAPE** (Target+Module, ad-hoc, single-host depth) vs. **Velociraptor** (agent-server, **VQL** queries across the fleet). The network is a **silent witness** (**NetFlow** = metadata/phone-bill vs. **PCAP** = full packets/tape-recording); **snapshots** and **cloud APIs** enable “no-touch” acquisition; **anti-forensics** (BYOVD, EDR blinding) and **TLS 1.3** reduce visibility. Forensic-by-design = immutable WORM logs, NTP everywhere, legal mandate.

- Q1.** Explain the “Dead Box fallacy”: three reasons seizing-and-imaging disks does not scale, and what the modern triage approach does instead.
- Q2.** In KAPE, distinguish a **Target** from a **Module**, and describe the Identify → Extract → Process workflow.
- Q3.** List four “golden” Windows triage artifacts (e.g. \$MFT, Prefetch, registry hives, Event Logs, LNK) and say what each reveals.
- Q4.** Compare KAPE and Velociraptor across architecture, speed, analysis and best use case.
- Q5.** What is VQL and why does “pushing queries instead of tools” scale to thousands of machines? Write (in plain words) a query to find PowerShell processes launched with `-enc`.
- Q6.** Compare **NetFlow** and **PCAP** on storage cost, retention and forensic use. Why is the network “harder to deceive” than the endpoint?
- Q7.** Explain how TLS 1.3 reduces network visibility and the recommended workaround (endpoint-side visibility).
- Q8.** Describe the cloud “no-touch” snapshot workflow (snapshot → clone to isolated VPC → attach to forensic VM) and its two advantages (zero downtime, zero observer effect).
- Q9.** Define **BYOVD** and **EDR/triage blinding**. Why do these mean an auditor must cross-reference endpoint triage with a “network witness”?
- Q10.** Distinguish a **SIEM** from a **forensic data lake** in purpose and retention, and explain why WORM/immutable storage matters for NIS2/DORA.
- Q11.** List four Windows lateral-movement indicators (WMI, RDP Logon Type 10, PowerShell Remoting, SMB C\$ access) and the rough exfiltration channel split (cloud/DNS/ICMP) you studied.
- Q12.** Explain the “observer effect” in remote RAM acquisition: why is a 128 GB memory image over the network a “smear,” not a perfect snapshot, and what risk does it pose to the host?

12. Synthesis & Cross-Cutting Scenarios

Context — Integrative

Exam questions often force you to *connect* compliance and forensics: a regulation imposes a duty, a control implements it, and forensics proves it worked. These integrative questions rehearse exactly that bridge.

- Q1.** A financial firm suffers a major ICT outage. Walk through the obligations it faces under **DORA** (reporting + forensic analysis) and **NIS2**, and name the ISO/CSF controls that would have prepared it.
- Q2.** Map the incident lifecycle across frameworks: align the NIST CSF functions (Detect, Respond, Recover) with ISO 27035 phases and the Monitoring→IR→Forensics pipeline from the forensics lessons.
- Q3.** “A checkmark on an audit doesn’t mean a control works.” Explain how forensic verification acts as quality control for the auditor, and why the best auditors have a forensic background.

- Q4.** A SIEM alert fires on suspicious PowerShell. Describe an automated, forensically-sound response that preserves evidence (triggered triage, snapshot, hashing) while restoring service.
- Q5.** Tie together three ISO 27002 controls (A.8.15 Logging, A.8.16 Monitoring, A.8.17 Clock synchronization) with the five pillars of forensic readiness, explaining the dependency.

Coverage: lessons T1–T10 + DORA/SOC2 + Autopsy/Volatility labs. Star (★) questions are re-mapped from the 2022 official exam.

ANSWER KEY

Model answers to every question. Try to answer on your own *first* — then read these to check depth and correct any gaps.

1. ISS Compliance (Assessments, Audits, Governance)

- A1. Assessment** = an internal, improvement-oriented health-check of the controls on a system; it is *non-attributive* and produces recommendations. **Audit** = an *independent*, rigorous, pass/fail evaluation of whether controls exist, are effective and comply with policy/regulation. *Two differences:* (i) **Blame** — audit findings can be attributed to specific individuals/groups, an assessment is non-attributive; (ii) **Consequences** — an audit has clear pass/fail outcomes with penalties / certification and can create a “sense of fear,” whereas an assessment only identifies gaps to improve, with no penalty.
- A2.** 1. Categorize the information system (data + impact of an incident); 2. Select a baseline set of controls and supplement as appropriate; 3. Implement and document the controls; 4. Assess the controls (do they produce the desired results?); 5. Authorize operation based on an acceptable level of risk; 6. Monitor the controls continuously.
- A3. Risk management** mitigates risk through controls (identify → evaluate → act to lessen risk). **Compliance** supports risk management by verifying that the desired controls are actually in place and conform to policy/regulation. **Governance** adds the top layer: running the organization with complete, accurate information and management processes, setting direction and accountability within which RM and compliance operate.
- A4.** It violates **auditor independence / objectivity**. Auditors must never audit applications, processes or systems they designed or created — it is a conflict of interest and they cannot impartially evaluate their own work, so the evaluation is no longer independent.
- A5. Financial** (does the financial statement reflect the firm’s financial position?); **Compliance** (adherence to laws, regulations, industry requirements); **Operational** (adherence to policies, procedures and operational controls); **Investigative** (examines records/processes after suspicious activity or alleged violations); **IT** (addresses IT system risk exposures).
- A6.** Both are **scope restrictions**: *limiting the time frame* and *withholding relevant historical records / past-incident information*. Impact: they prevent the discovery of audit evidence and restrict audit procedures, so the auditor cannot gather sufficient evidence to form a reliable opinion — weaknesses go undetected and the audit conclusion is incomplete/unreliable.
- A7.** Examples (any four with a fix): *Lack of alignment to business objectives* → tie compliance to business goals and show ROI; *Misunderstanding the rationale for compliance* → awareness/education on why it matters; *Funding shortfalls* → secure executive sponsorship by quantifying the cost of non-compliance; *Lack of top-management support* → board accountability and a named owner; *Misconception of what compliance delivers* → set realistic expectations and scope.
- A8. Policy** = high-level mandatory statement of intent/commitment; **Standard** = mandatory specific requirements that implement the policy; **Guideline** = recommended (non-mandatory) best practice. Binding order: **Policy** > **Standard** > **Guideline** (the framework continues Policy → Standard → Guideline → Procedure).

2. Planning an Audit & the Seven Domains

- A1. ★** A concrete control: *include mandatory information-security clauses and a “right-to-audit” in every supplier contract, plus security due-diligence before onboarding and ongoing monitoring/review of supplier services* (A.5.19–A.5.22). Justification: the supply chain is a major attack vector; a contractual + due-diligence control forces suppliers to meet defined security requirements and lets the organization verify and enforce them, reducing third-party/supply-chain risk.
- A2. ★** Four System/Application-Domain controls (justify each): (1) *Harden servers to an authorized baseline* — removes unnecessary services and shrinks the attack surface; (2) *Privileged/secure access control & least privilege* (A.8.2/8.5) — limits who can reach the application and data; (3) *Technical-vulnerability management / patching* (A.8.8) — application servers are prime targets for known CVEs; (4) *Logging & monitoring* (A.8.15/8.16) — detects attacks and supplies forensic evidence. (Backups, secure coding, and cryptography are also defensible choices.)
- A3.** Domains: **User, Workstation, LAN, LAN-to-WAN, WAN, Remote Access, System/Application. LAN-to-WAN:** equipment = routers, firewalls and intrusion-detection devices; main concern = it is the boundary to the public Internet (public IP addresses), so it requires the highest level of perimeter security against external threats.
- A4. Configuration management** ensures changes are requested, evaluated and authorized and keeps a documented known-good state across the lifecycle; **change management** provides the method to track changes and detect *unauthorized* ones. Five steps: 1. Identify/request change; 2. Evaluate the request; 3. Decision/response; 4. Implement the approved change; 5. Monitor the change.
- A5.** Any five of: IP addresses, operating system + patch level, hardware specifications, installed software, protocols, service configuration, user accounts, password settings, audit-log settings, the firewall rule set.
- A6. Adversarial** = a malicious hacker/third party launching an attack; **Accidental** = an employee mistakenly deleting data or mis-configuring a server; **Structural** = a failure arising from how the system is built (hardware ageing, software bug, resource exhaustion); **Environmental** = fire, flood, power loss or other natural disaster.
- A7.** Risk depends on: (1) the *likelihood* of the threat exploiting the vulnerability; (2) the *impact* if it succeeds; (3) the *sufficiency of controls* to eliminate/reduce it. Trade-offs to decide on a control: **Cost** (is the risk reduction worth the price?), **Operational impact** (does it hurt system performance?), **Feasibility** (is it technically achievable and acceptable to users?).
- A8.** Four documents: administrative (written policies), system documentation, procedural documentation, network-architecture diagrams, vendor support/access agreements. Knowing the existing *policy framework* matters because frameworks underpin the risk/security program and policy creation; identifying it lets the auditor align the audit with that framework, giving better alignment between the organization’s policy and the audit.
- A9.** Because controls must be *tested and monitored to know they actually work* — a control that exists but is ineffective is worthless — and monitoring detects problems before it is too late and links IT performance back to business goals (and to CIA assurance).

3. ISO/IEC 27000 Family & the ISMS

- A1.** **ISO 27001** is the only certifiable standard. Certification attests that the organization runs an **ISMS conforming to the standard** — a systematic, risk-based management system that protects information CIA, selects controls via risk assessment, documents and implements them, and continually improves. It attests the *management system*, not that the organization is perfectly secure.
- A2.** 27001 = *what* (Annex A objective: “access to information should be controlled”); 27002 = *how* (guidance: “use MFA, role-based access control and least privilege”). 27001 is the certifiable management framework of control objectives; 27002 gives detailed implementation best practice.
- A3.** An **ISMS** is a systematic approach to securing the CIA of corporate information assets, based on PDCA and built from controls selected by regular risk assessment. Four categories: **Organizational (A.5)**, **People (A.6)**, **Physical (A.7)**, **Technological (A.8)**.
- A4.** **Plan:** define scope/policy, run the risk assessment, select controls. **Do:** implement and operate the controls/processes. **Check:** monitor, measure and audit ISMS performance against objectives. **Act:** take corrective and improvement actions (continual improvement).
- A5.** Without top-management commitment the ISMS lacks **funding, authority and governance**. Leadership must drive it, assign roles/responsibilities and establish the information-security policy; security needs resources and an organizational mandate only senior management can grant.
- A6.** 27005 = risk management; 27017 = cloud security; 27018 = PII protection in the cloud; 27035 = incident management; 27701 = privacy information management (PIMS/GDPR).
- A7.** Benefits (any two): structured risk management, lower financial/reputational loss, better business continuity/resilience, greater customer trust, competitive advantage. Consequences of not adopting (any two): data breaches/cyberattacks (e.g. Equifax, SolarWinds), legal/financial penalties, reputational damage.

4. ISO 27002 Controls & Risk

- A1.** **Organizational (A.5)** — e.g. policies, supplier relationships, threat intelligence; **People (A.6)** — e.g. screening, security awareness training; **Physical (A.7)** — e.g. physical perimeters, clear-desk/clear-screen; **Technological (A.8)** — e.g. secure authentication/MFA, malware protection, logging, encryption.
- A2.** (a) MFA = **Preventive**; (b) SIEM monitoring = **Detective**; (c) restore from backup = **Corrective**; (d) firewall rules = **Preventive**.
- A3.** The **Statement of Applicability** lists which Annex A controls apply, whether they are implemented, and the justification for each inclusion/exclusion. The risk assessment identifies and rates risks; based on the risk levels the organization selects appropriate controls from the ISO 27002 catalogue, records them in the SoA, and uses 27002 for implementation guidance.
- A4.** **Avoid** (disable USB ports to remove malware exposure); **Transfer** (buy cyber insurance / outsource); **Mitigate** (deploy firewalls + IDS to cut likelihood/impact); **Accept** (tolerate the minor risk of occasional password resets). *Accept* is the rational choice when the cost of mitigation exceeds the expected loss and the risk sits within the organization’s risk appetite.

- A5. Risk appetite** = the amount and type of risk an organization is willing to take to meet its objectives (varies by sector/culture). During **risk evaluation** each risk level is compared against the appetite: risks above appetite must be treated (mitigate/avoid/transfer), risks within appetite may be accepted; remaining risks are prioritized by severity and business impact.
- A6.** By the **cost** trade-off the control is not justified — its cost exceeds the risk reduction it buys. The organization should *not* deploy that control: instead accept the risk (if within appetite), find a cheaper control, or transfer it via insurance. Never spend more on protection than the asset/loss is worth.
- A7.** A.5.7 **Threat Intelligence** → supplies IoCs to hunt for and tune detection; A.8.16 **Monitoring** → generates the alerts that trigger forensic triage and the audit logs investigators read; A.8.17 **Clock synchronization** → the time-sync readiness pillar that lets events be correlated across machines and timelines be admissible.

5. Other ISO Standards, Implementation & Certification

- A1.** In **SaaS** the provider controls the application, platform, virtual *and* physical infrastructure — the customer manages only its data, users and access. In **IaaS** the customer controls the application (and shares the platform) while the provider controls the virtual and physical infrastructure. The **shared-responsibility** idea (ISO 27017): security duties are split between provider and customer according to the service model, made explicit in a responsibility matrix.
- A2. ISO 27018** protects PII processed in the cloud and makes providers follow privacy best practice. Two principles (any two): user-consent management, PII encryption/anonymization, data-residency requirements, right to erasure.
- A3.** Energy/critical infrastructure is a high-value target (ransomware, nation-state) and needs secure IT/OT integration, so it gets **ISO 27019**. An OT/ICS-specific threat: SCADA-system hacking or smart-grid vulnerabilities.
- A4. Stage 1** = documentation audit / readiness assessment — verifies the required policies, risk assessments and controls (SoA) exist and flags gaps. **Stage 2** = certification audit — on-site assessment of the *actual implementation*; auditors test security processes, risk management and employee awareness; if it passes, the certificate (valid 3 years) is issued.
- A5. First-party (internal)** audit: performed by internal teams / independent internal auditors to prepare for certification and find non-conformities early. **Third-party certification** audit: performed by an accredited certification body (BSI, TÜV, SGS) and is required to obtain the certificate.
- A6.** Detection & Reporting; Assessment & Classification; Response & Containment; Recovery & Lessons Learned.
- A7.** (i) No proper risk assessment → security gaps (*lesson: risk assessment is mandatory*); (ii) employees ignored policies → HIPAA violations (*lesson: people are the weakest link, training is critical*); (iii) internal audits not conducted → non-compliance went undetected (*lesson: regular audits maintain compliance*). Poor documentation is a fourth (*lesson: documentation is mandatory*).
- A8.** Undergo **annual surveillance audits** by the certification body, a full **recertification audit every 3 years**, and **continuous ISMS improvement** (update risk assessments

and controls for new threats, ongoing training, corrective actions from incidents).

6. NIST Cybersecurity Framework 2.0

- A1. Govern** (embed cybersecurity in leadership/strategy/risk, accountability); **Identify** (assets, risk, supply chain); **Protect** (access control, encryption, training, patching); **Detect** (monitoring, anomalies, logging); **Respond** (incident response, analysis/forensics, communication); **Recover** (disaster recovery, backups, lessons learned).
- A2. Govern**, added in CSF 2.0 (2024). It was added to embed cybersecurity into organizational leadership, strategy, governance and risk management — making it a board/business responsibility rather than a purely IT issue. It embeds governance, policy, accountability and supply-chain risk management.
- A3.** An **Implementation Tier** describes *maturity* — how rigorously the organization manages cyber risk (1 Partial, 2 Risk-Informed, 3 Repeatable, 4 Adaptive). A **Profile** *tailors* the framework to the organization's needs/requirements (a Current state vs. a Target state). Tiers measure maturity; profiles customize.
- A4.** Build a **Current Profile** (assess today's controls against the CSF functions / categories), define a **Target Profile** (desired state from risk tolerance/requirements), run a **gap analysis** between them, then create a prioritized **action plan** (high-impact gaps first), implement it and update the profile.
- A5.** MTBD → **Detect**; MTTR → **Respond**; patch-management time → **Protect**; phishing click-rate → **Govern** (awareness training).
- A6.** Any two: it is referenced in regulations/compliance frameworks (SEC rules, HIPAA) and helps prove *due diligence*; it maps to ISO 27001/800-53/CIS/Zero Trust; and it creates a common risk language between security teams and executives.
- A7.** AI-based attacks → **Detect** (AI-powered threat intel); cloud misconfiguration → **Govern & Protect** (cloud compliance); ransomware double extortion → **Recover** (robust backups + IR); supply-chain attacks → **Identify** (third-party risk).

7. NIS2 & GDPR

- A1. ★ ENISA** is the EU Agency for Cybersecurity, given a *permanent* mandate by the Cybersecurity Act (Reg. 2019/881). Its main function is to act as the central hub for EU-wide cooperation: exchanging *threat intelligence and best practice* between member states, supporting national *incident-response readiness* and the cooperation of national CSIRTs, and developing/operating the EU *cybersecurity certification schemes*. In short: coordinate cooperation, certification and coordinated incident response to raise the EU's common cyber-resilience baseline.
- A2.** **24h** early warning → **72h** full incident report → **1-month** final assessment, sent to the national **CSIRT or competent authority**.
- A3. Essential Entities** must implement all NIS2 requirements under the highest scrutiny (proactive/ex-ante supervision). **Important Entities** are subject to audits but lower supervision intensity (reactive/ex-post) unless they pose a critical risk. Size threshold: generally >50 employees or >€10M turnover; the entity must be EU-based/serving the EU and in a covered sector (or critical regardless of size).

- A4.** Senior management must *approve and oversee* the security risk-management measures and *receive basic cybersecurity training*, and can be held **personally liable** for negligence/non-compliance. Penalties: fines up to **€10M or 2% of global annual turnover** (whichever is higher), plus possible operational bans.
- A5.** Bases: **Consent, Contract, Legal obligation, Vital interests, Public task, Legitimate interests**. Shipping address → **Contract** (needed to perform the purchase/delivery). Fraud-detection log → **Legitimate interests** (security/fraud prevention, subject to the balancing test).
- A6.** **Art. 33:** the controller must notify the supervisory authority without undue delay, *no later than 72h* after becoming aware, describing the breach's nature, likely consequences and measures taken. **Art. 34:** notifying the affected individuals is *not* required if the data was protected (e.g. strongly encrypted/unintelligible) or the high risk is no longer likely to materialize.
- A7.** GDPR still applies through **Art. 3(2)** (territorial scope): it covers a non-EU controller/processor when it *monitors the behaviour* of data subjects *in the EU* (tracking cookies / targeted ads) — an EU establishment is not required.
- A8.** **Controller** determines the purposes and means of processing and is responsible for compliance; **Processor** processes on the controller's behalf, following its instructions and contract; **DPO** oversees the data-protection strategy and GDPR compliance, acting independently as an expert adviser.
- A9.** **Lower tier:** up to 2% of global turnover or €10M — administrative breaches (record-keeping, processor contracts, DPO/notification failures). **Higher tier:** up to 4% or €20M — violations of data-subject rights, the basic processing principles, the lawful basis/consent, or international-transfer rules.
- A10.** Any four of: informed, access, rectification, erasure, restrict processing, portability, object, automated decision-making. *Right to be forgotten* can be lawfully refused when there is an overriding legal obligation to retain the data (e.g. tax/accounting records), or for freedom of expression, public-interest or legal-claim grounds.

8. DORA, EU Cybersecurity Act & SOC 2

- A1.** DORA targets the EU **financial** sector (banks, investment firms, payment institutions, crypto-asset service providers) *and* the **third-party ICT providers** (e.g. cloud providers) that support them. ICT risk-management cycle: **Identify → Assess → Mitigate → Monitor**.
- A2.** **Art. 13** requires post-incident reviews of major ICT disruptions to include *forensic analysis*, and financial entities must determine “the quality and *speed* of performing a forensic analysis.” Speed of analysis therefore becomes a compliance metric — which only **forensic readiness** (ready capability, pre-approved external retainer, immutable logs) can deliver.
- A3.** Levels: **Basic, Substantial, High**. **Mutual recognition** means a product/service certified in one member state is recognized across the whole EU — removing duplicate audits and conflicting national standards and easing cross-border business under one common assurance baseline.
- A4.** **Type I** = a point-in-time assessment of whether the controls are appropriately *designed* as of a specific date. **Type II** = tests the *operating effectiveness* of the controls over a period

(typically 3–12 months) — more rigorous, demonstrating consistent long-term adherence.

- A5. Security** (mandatory/common to every report), **Availability**, **Processing Integrity**, **Confidentiality**, **Privacy**.
- A6. Inquiry** (ask staff how a process runs), **Inspection** (review documentation/configs/logs), **Observation** (watch the control performed, e.g. badge entry), **Re-performance** (the auditor independently re-executes the control, e.g. re-runs an access review).
- A7. Benefit:** a single integrated approach reuses shared controls across NIS2/DORA/GDPR (data protection, resilience, incident reporting), reducing duplicated effort and leveraging existing compliance structures. **Challenge:** avoiding conflicting requirements and harmonizing compliance strategies across overlapping regimes.

9. Digital Forensics & Forensic Readiness

- A1. ★** Two situations: (i) an investigator finds evidence implicating the very manager who commissioned the audit — a code of ethics enforces *objectivity and independence*, preventing them from hiding it or yielding to pressure; (ii) during collection the investigator can see personal/private data unrelated to the case — a code of ethics/deontology mandates *confidentiality* and acting only within the *authorized scope*, protecting privacy. Ethics underpins impartiality, confidentiality and the credibility/admissibility of the findings.
- A2.** The **auditor** (compliance lens) verifies that controls *exist* and are correctly *designed* against a standard (ISO/NIS2). The **investigator** (forensic lens) *reconstructs what actually happened* from artifacts — focusing on activity and intent (“what did the attacker really do?”).
- A3. Locard:** “every contact leaves a trace” — any interaction creates digital artifacts. Windows examples (any two): LNK files / Shellbags (file access), Registry & USB logs (devices), RAM strings / pagefile (process activity), Prefetch (program execution).
- A4.** Most → least volatile: **Registers & Cache** → **RAM** → **Network state (connections/ARP)** → **Disk/persistent media**. “Reboot first” wipes the top three volatile layers — losing running (fileless) malware, decryption keys, live connections and unsaved data — so it actively destroys evidence.
- A5.** Hash the original source, create the forensic image, hash the image; if **H(original)=H(image)** the copy is a faithful, untampered duplicate (a digital fingerprint), because a single changed bit changes the whole hash — there is no “close enough.” **Dual hashing** (MD5 + SHA-256) is used to mathematically rule out a deliberate hash *collision* being used to fake integrity.
- A6.** A **hardware write-blocker** sits between the suspect drive and the workstation, allowing read commands but *intercepting and dropping write commands*, preserving the original. Without it, Windows auto-writes “System Volume Information,” updates “Last Accessed” timestamps and creates “Thumbs.db” — tampering with the crime scene.
- A7. Dead** acquisition images a powered-off drive (safest, easiest to hash, no change); **live** acquisition images while the OS runs (alters the system — minimal-footprint principle) but is the *only* way to capture RAM and encryption keys. Live is the only option when the disk is full-disk encrypted (BitLocker/FileVault) and you lack the recovery key — capture the keys while they are unlocked in memory.
- A8.** A **logical copy** duplicates only the files the filesystem recognizes (what you see in Explorer); a **physical bit-stream** image clones the disk sector-by-sector (dd). Only the bit-stream

captures (any two): deleted files, unallocated space/slack, partition tables, hidden partitions — hence it is the same size as the physical disk.

- A9. Executable 4D 5A (“MZ”); PDF 25 50 44 46 (“%PDF”); JPEG FF D8 FF. File extensions are mere suggestions and can be renamed (`malware.exe`→`picture.jpg`); the header bytes define the *true* type, so a forensic tool reads the header, not the extension.
- A10. Pillars: **time synchronization, advanced logging policy, legal mandate / right to monitor, technical triage tools, staff training (first responder)**. Time sync: if clocks drift you cannot prove *exactly when* an event happened or correlate “login on A” with “file access on B,” so the evidence can be thrown out in court — enterprises often need sub-second sync (NTP, Stratum 1/2).
- A11. NIS2 (Art. 21) requires an incident-handling capability; if you *cannot prove how a breach happened* (no logs), regulators may deem your security **negligent**. Forensics supplies the documented proof for the mandatory **24/72-hour** breach notifications — without it the report is “guesswork,” exposing the company to large fines.
- A12. **IR goal** = business continuity (wipe, restore, get back online fast). **Forensic goal** = preservation (touch nothing, identify the intruder). Wiping to recover destroys evidence and may leave the backdoor in place. Compromise = **forensic-aware IR**: capture a triage image/snapshot first (≈ 10 min) to preserve evidence, *then* restore — “snapshots over wipes.”

10. Endpoint / Memory Forensics & Volatility 3

- A1. About 90% of modern malware lives purely in RAM; “fileless” threats never touch the disk, so disk-only/static analysis and AV miss them. RAM-only items (any three): plaintext passwords/decrypted keys, transient network connections, injected malware code with no file backing, recent CLI commands, clipboard contents, decrypted browser URLs.
- A2. **Physical RAM dump** (`.raw/.bin`) = bit-for-bit copy of physical memory; **hiberfil.sys** = compressed RAM snapshot written to disk on hibernate; **pagefile.sys** = virtual memory paged to disk to free physical RAM; **crash dump** (`.dmp`) = memory state the OS saves after a kernel panic/BSOD.
- A3. Volatility 2 needed manually pre-generated **Profiles** (KDBG) and analysts struggled with missing profiles for new patches; Volatility 3 uses **Symbols** (PDB → ISF JSON) downloaded on-the-fly, making profile management transparent. **Automagic** auto-detects the OS, scans the physical/virtual layers and handles address translation (DTB/CR3) and configuration that previously required manual profiles/offsets.
- A4. The course orders intrusiveness as **DMA < Network < Software** (DMA has the *smallest software footprint* on the target). DMA *advantage*: minimal interaction with the target OS and it can read memory even when the OS is locked/unresponsive (high-speed bus access). *Limitation*: it needs specific physical hardware/access, can be blocked by IOMMU/VT-d, and risks crashing or corrupting the system.
- A5. `pslist` = a flat list of *active* EPROCESS structures (walks the linked list); `pstree` = the parent-child hierarchy (spot orphaned/suspicious children); `psscan` = *carves* memory for EPROCESS objects, so it finds **hidden/unlinked or terminated** processes that `pslist` misses (it scans rather than trusting the active list, defeating DKOM unlinking).
- A6. `windows.netscan` (or `windows.netstat`) lists active TCP/UDP sockets with local/remote IPs and the owning PIDs. Suspicious pattern: *high-number ports connecting to external IPs*,

typical of Command & Control / beaconing.

- A7.** `windows.malfind` flags injected code: pages with **RWX** (Read-Write-Execute) permissions, memory *not backed by a file on disk*, and shellcode/PE headers (“MZ”). An “MZ” (0x4D5A) string in `explorer.exe`’s heap means a PE (EXE/DLL) was mapped/injected into that process — a hallmark of process injection/hollowing.
- A8.** `windows.registry.printkey --key "Software\Microsoft\Windows\CurrentVersion\Run"` enumerates autorun/startup entries straight from the in-memory hive. Run-key entries auto-launch programs at boot/logon — a classic malware **persistence** mechanism.
- A9.** `windows.dumpfiles --pid [PID]` (extract cached files) and `windows.memmap --pid [PID] --dump` (dump the process’s memory). Analyze the extracted executables in **Ghidra** or **IDA Pro**, or upload to **VirusTotal**.
- A10.** **MemProcFS** mounts the memory image as a *virtual drive* (M:), presenting processes/network/registry as folders and files (`sys/proc`, `sys/net`, `sys/registry`) instead of CLI plugins. Benefit: browse RAM like a hard drive with standard tools (AV scanners, **strings**), with an instant built-in timeline — and it can even attach to live memory.
- A11.** Immediately compute a **cryptographic hash (SHA-256)** of the image to prove zero changes, and record the **BIOS time vs. real-world time offset** so the dump’s timestamps can be aligned/corrected during timeline analysis (the system clock may be skewed).

11. Scaling the Investigation

- A1.** Seize-and-image does not scale because: (1) it is high-friction for business operations; (2) storage is massive (a 2 TB disk = a 2 TB image, × thousands of endpoints); (3) it misses volatile data (RAM, network state). Modern **trriage** instead deploys agents to collect only the high-value “golden” artifacts remotely in <10 minutes (targeted, low friction).
- A2.** A **Target** is the list/definition of files to grab (e.g. **\$MFT**, event logs, registry hives); KAPE copies them via *raw disk access* while preserving timestamps. A **Module** is an executor that runs an external tool (Hayabusa, RegRipper) against the collected data to produce CSV/JSON reports. Workflow: **Identify** targets → **Extract** (raw copy) → **Process** (modules parse into scannable formats).
- A3.** **\$MFT** (NTFS Master File Table) = the master timeline of file creation/deletion; **Prefetch** = which applications ran and when; **Registry hives** (SYSTEM/SOFTWARE/SAM/NTUSER) = configuration + user persistence; **Event Logs** = logons (4624) and PowerShell (4104); **LNK files** = evidence of file access even after the file is deleted/moved or accessed from removable media.
- A4.** **Architecture:** KAPE ad-hoc/tool-based vs. Velociraptor agent-server/query-based. **Speed:** KAPE extremely fast per host vs. Velociraptor near-instant across the fleet. **Analysis:** KAPE needs external viewers vs. Velociraptor’s built-in dashboard & VQL. **Best for:** KAPE a deep dive on a single host vs. Velociraptor live hunting/triage across thousands.
- A5.** **VQL** (Velociraptor Query Language) treats endpoints like SQL tables — you *query* instead of scan. Pushing lightweight *queries* (not heavy tools) avoids the “agent-bloat” that crashes systems and returns results near-instantly across thousands of machines. Plain-words query: *select the name, command line and exe from the process list where the exe is powershell.exe and the command line contains -enc.*

- A6.** **NetFlow** = metadata (the “phone bill”: src/dst IP, ports, protocol), low storage, retain 12+ months, ideal for tracing C2 over time. **PCAP** = full packets (the “tape recording”), extreme storage, retain days/weeks, essential for carving payloads. The network is “harder to deceive” because endpoints can lie (malware hides processes) but the traffic still physically crossed the wire — “the wire (almost) never lies.”
- A7.** TLS 1.3 *encrypts the handshake* (hiding certificates/extensions), so network sensors see less of the content. Workaround: shift to **endpoint-based** network visibility (e.g. **netstat** from RAM) where the data is decrypted at the host.
- A8.** (1) **Snapshot** the suspected volume via the cloud API; (2) **clone** the snapshot into a new volume in an isolated forensic VPC/VNet; (3) **attach** it to a clean forensic VM as a secondary disk. Advantages: *zero downtime* on production and *zero observer effect* on the snapshot disk (and it still captures deleted/unallocated space).
- A9.** **BYOVD** = the attacker drops a signed but *vulnerable* driver to gain kernel privileges, then uses a kill-switch to terminate protected triage/EDR processes. **EDR/triage blinding** = bypassing userland hooks via *direct syscalls* so the agent reports “healthy” while malicious code runs invisibly. Because a compromised agent’s audit trail becomes “curated fiction,” the auditor must cross-reference endpoint triage against an independent *network witness* and rely on tamper-protected agents.
- A10.** A **SIEM** is built for real-time detection/alerting and often deletes logs after 30–90 days (cost). A **forensic data lake** is built for investigations: raw, compressed, hashed logs kept 1–2 years. **WORM/immutable** storage stops attackers (or insiders) from clearing their tracks/altering logs — proving log integrity and chain of custody for NIS2/DORA “due care.”
- A11.** **WMI** (remote code execution; Event ID 5858/5861 for persistence), **RDP** (Event 4624, Logon Type 10 — unusual internal logins), **PowerShell Remoting** (Invoke-Command/Enter-PSSession in ScriptBlock logs), **SMB** (mounting a neighbor’s C\$/Admin\$). Exfiltration split: *Cloud Storage HTTPS* ≈70%, *DNS tunneling* ≈15%, *encoded ICMP/SMTP* ≈15%; look for beaconing (regular small packets) plus large outbound spikes.
- A12.** Imaging 128 GB over a 1 Gbps link takes ≈17 minutes, during which the RAM keeps changing (processes run), so the image is a “smear,” **not an instantaneous snapshot**; the acquisition agent itself occupies memory pages and can overwrite small evidence (e.g. shellcode in unallocated space). Host risk: noticeable lag and the kernel-space tool can trigger a BSOD / instability.

12. Synthesis & Cross-Cutting Scenarios

- A1.** Under **DORA** the firm must report the major ICT incident to the authorities (by the end of the next business day for major incidents) and run a post-incident review *including forensic analysis* (Art. 13). Under **NIS2** it must send the 24h early warning, 72h report and 1-month final assessment and demonstrate an incident-handling capability (Art. 21), with management accountable. Preparatory controls: ISO A.8.15/16 logging+monitoring, A.8.17 clock sync, A.5.24–28 incident management/evidence collection, A.8.13 backups; NIST CSF Detect/Respond/Recover; and the five forensic-readiness pillars.
- A2.** **Detect** ↔ ISO 27035 *Detection & Reporting* ↔ Monitoring/SIEM alerts; **Respond** ↔ *Response & Containment* ↔ Incident Response (the “interceptor”); **Recover** ↔ *Recovery & Lessons Learned* ↔ the post-mortem fed back to Auditing/Management. Forensics supplies the root cause that drives IR, and the post-mortem feeds the next audit cycle.

- A3.** A checkmark on an audit does not prove a control *works* (the “checklist fallacy”), and auditors are often misled — usually through ignorance, sometimes deliberately. Forensic verification looks at *what the machine actually did* rather than what people claim, providing “ground truth”; its findings drive the next audit cycle and tune monitoring. That is why the best auditors have a forensic background.
- A4.** Forensically-sound automated response: the SIEM/EDR alert *triggers automated triage* (Velociraptor/KAPE) to grab RAM + key artifacts and *auto-snapshots* the VM (disk+RAM) on the high-severity alert; every collection is *hashed (SHA-256)* and written to *immutable WORM/Object-Lock* storage with an audit-logged chain of custody; only then is the service contained/restored from a clean backup. This preserves the evidence (e.g. ScriptBlock/AMSI buffers showing what the script did) while still meeting continuity.
- A5. A.8.15 Logging** produces the forensic-quality logs (the *advanced-logging* pillar); **A.8.16 Monitoring** generates the alerts that trigger triage (the *triage-tools* pillar); **A.8.17 Clock synchronization** is the *time-sync* pillar that makes the logs correlatable and admissible. Dependency: logs are useless without synchronized clocks (you cannot correlate events), and monitoring is useless without logs to watch — together they deliver forensic readiness: collect useful evidence, correlate it across machines, and prove the timeline.